

The background of the slide features a close-up photograph of a person's hand in a dark suit sleeve, wearing a wooden bead bracelet, pressing a button on a black calculator. The calculator sits on a wooden desk. In the background, there are blurred papers with charts and a green highlighter.

Annualized Loss Expectancy (ALE) Methodology

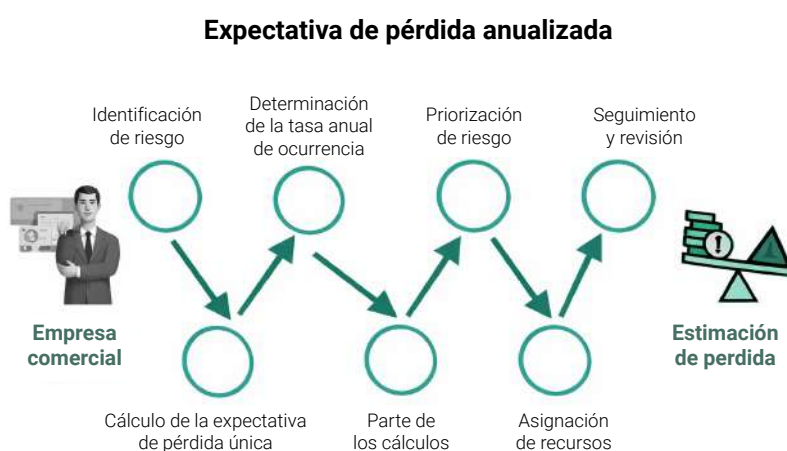
Marco normativo y gestión de riesgos

Servicio Nacional de Aprendizaje - SENA

Medición de riesgos - Expectativa de pérdida anualizada

¿Qué es la expectativa de pérdida anualizada?

La Expectativa de Pérdida Anualizada (ALE) es un cálculo utilizado en la gestión de riesgos de seguridad de la información para estimar la pérdida financiera anual esperada debido a un riesgo o amenaza en particular. Se determina multiplicando la expectativa de pérdida individual por la tasa anual de ocurrencia de un evento determinado. Su propósito es proporcionar una base para la presupuestación y la asignación de recursos para iniciativas de ciberseguridad.



Su objetivo es respaldar la toma de decisiones comparando los costos de mitigación con las pérdidas potenciales del riesgo. También se centra en la monitorización y actualización continua de los cálculos para reflejar los cambios en el riesgo. Finalmente, ayuda a las organizaciones a priorizar y asignar recursos para mitigar los riesgos con mayor impacto financiero potencial.

- La expectativa de pérdida anualizada es un método para calcular el impacto financiero esperado del riesgo durante un período determinado, normalmente un año.
- Proporciona una base para la toma de decisiones objetiva, ya que calcula el impacto financiero esperado del riesgo basándose en datos y estándares de la industria.
- Se determina multiplicando la expectativa de pérdida única por la tasa anual de ocurrencia.
- La expectativa de pérdida anualizada primaria ayuda a las organizaciones a asignar recursos, como presupuesto y personal, de forma más eficaz para reducir el riesgo. Además, permite a las organizaciones supervisar y evaluar el panorama de riesgos y minimizar las pérdidas financieras.

Explicación de la expectativa de pérdida anualizada

El método de expectativa de pérdidas anualizada proporciona una base integral y objetiva para que las organizaciones tomen decisiones informadas sobre la gestión de riesgos y asignen recursos eficazmente para minimizar las pérdidas financieras. Proporciona a las organizaciones la información necesaria para tomar decisiones sobre la asignación de recursos, la inversión en nuevas tecnologías y la implementación de políticas y procedimientos.

El ALE es un indicador dinámico que debe actualizarse con frecuencia a medida que el entorno de amenazas cambia y se accede a más datos. La combinación del ALE con otros enfoques de evaluación de riesgos puede proporcionar una visión completa del perfil de riesgo de una organización. Es una herramienta útil para que las empresas establezcan prioridades para sus iniciativas de seguridad, asignen recursos de forma inteligente, comuniquen la importancia de las iniciativas de seguridad a las partes interesadas y les muestren el valor de sus iniciativas de seguridad.



Pasos

Su mecanismo consta de los siguientes pasos:

- 1. Identificación de riesgos:** identificar todos los riesgos y amenazas potenciales que una organización puede enfrentar.
- 2. Cálculo de la expectativa de pérdida única:** determine el costo esperado de una sola ocurrencia de cada riesgo. Incluye costos directos e indirectos, como reparación, reemplazo y tiempo de inactividad.
- 3. Determinación de la tasa anual de ocurrencia:** estime el número de veces que se espera que ocurra un riesgo específico en un año determinado. Esto puede hacerse mediante datos históricos, estándares del sector o juicio de expertos.
- 4. Parte del cálculo:** multiplicar la expectativa de pérdida única por la tasa anual de ocurrencia. Esto determina la pérdida financiera esperada por año debido a un riesgo específico.
- 5. Priorización de riesgos:** priorizar los riesgos en función de sus cálculos, enfocándose primero en mitigar aquellos con mayor impacto financiero.
- 6. Asignación de recursos:** asignar recursos, como presupuesto y personal, para implementar medidas de mitigación de riesgos y reducirlos.
- 7. Monitoreo y revisión:** monitorear y revisar sus cálculos para reflejar los cambios en el panorama de riesgos y la tolerancia al riesgo de la organización.

Fórmula

La fórmula es la siguiente:

$$\text{ALE} = \text{SLE} \times$$

Dónde:

- SLE (expectativa de pérdida única) es el costo esperado de una única ocurrencia de un riesgo particular, incluidos los costos directos e indirectos, como reparación, reemplazo y tiempo de inactividad.
- ARO (tasa anual de ocurrencia) es el número de veces que se espera que ocurra un riesgo particular en un año determinado.

Entonces, el cálculo determina la pérdida financiera esperada por año debido a ese riesgo.

Ejemplo de cálculo

He aquí un ejemplo de cómo calcularlo:

Supongamos que una organización está considerando el riesgo de una filtración de datos. Dispone de la siguiente información:

1. Expectativa de pérdida única (SLE) = \$100,000

Esto representa el costo esperado de una sola violación de datos, incluidos los costos directos e indirectos, como pérdida de negocios, daño a la reputación y

2. Tasa anual de ocurrencia (ARO) = 2

Esto representa la cantidad de veces que la organización espera que ocurra una violación de datos en un año determinado según las estadísticas o la experiencia de la industria.

Usando la fórmula:

$$\text{ALE} = \text{SLE} \times \text{ARO} = \$100,000 \times 2 = \$200,000$$

Entonces, los datos de expectativa de pérdida anualizada son de \$200,000, lo que significa que esperan perder \$200,000 por año debido a violaciones de datos.

Ventajas

Las ventajas de utilizarlo en la gestión de riesgos de seguridad de la información incluyen las siguientes:

- 1. Objetividad:** proporciona una base integral y objetiva para la toma de decisiones, ya que calcula el impacto financiero esperado de los riesgos basándose en datos y estándares de la industria.
- 2. Priorización:** ayuda a las organizaciones a priorizar los esfuerzos de mitigación de riesgos en función del impacto financiero de cada riesgo, lo que les permite centrar sus recursos en los problemas con mayor potencial de pérdida.
- 3. Mejor asignación de recursos:** al comprender el impacto financiero potencial de los riesgos, las organizaciones pueden asignar recursos, como presupuesto y personal, de manera más efectiva para reducir el riesgo.
- 4. Gestión de riesgos mejorada:** ayuda a las organizaciones a monitorear y evaluar continuamente el panorama de riesgos, lo que facilita la implementación de estrategias efectivas de gestión de riesgos y minimiza las pérdidas financieras.
- 5. Mejor comunicación:** proporciona un lenguaje común para discutir los riesgos y su impacto potencial, mejorando la comunicación entre los diferentes departamentos y partes interesadas dentro de una organización.
- 6. Mayor responsabilidad:** proporcionar una comprensión integral del impacto financiero de los riesgos puede mejorar la responsabilidad por las decisiones de gestión de riesgos y ayudar a garantizar que se asignen los recursos correctos a los riesgos.

Preguntas frecuentes (FAQ)

¿Cómo se deriva la expectativa de pérdida anualizada de una amenaza?

La expectativa de pérdida única (SLE) y la tasa de ocurrencia anualizada (ARO) se pueden multiplicar para encontrar la expectativa de pérdida anualizada que generalmente resulta de una amenaza (ARO).

¿Qué es la exposición a la expectativa de pérdida anualizada?

Pérdida promedio. En su forma más básica, la comunicación de riesgos se basa en la exposición como métrica clave. En esencia, es la posible pérdida que enfrenta una empresa cuando decide invertir fondos, que pueden abarcar desde la compra de nuevos equipos hasta la implementación de procedimientos específicos dentro de la empresa.

¿Cuáles son los tipos de expectativa de pérdida anualizada?

Existen dos tipos:

- **Cualitativo:** Utiliza medidas subjetivas, como el juicio de expertos, para estimar la probabilidad y el impacto potencial de un riesgo. Se suele utilizar cuando no se dispone de datos o cuando se requiere un enfoque más subjetivo.
- **Cuantitativo:** Utiliza datos, como datos históricos o estándares del sector, para calcular la probabilidad y el impacto potencial de un riesgo. Como resultado, proporciona un enfoque más objetivo y basado en datos para estimar el impacto financiero de los